FOR SMALL BUSINESSES · NO IT TEAM REQUIRED

THE FIRST

24 HOURS

of a Cyberattack

A Practical Incident Response Guide for Small Businesses



PLUS **8** Ready-to-use Templates

CONTAIN THE DAMAGE · **PRESERVE** EVIDENCE · **ESCALATE** & RECOVER

HOUR-BY-HOUR PLAN · CHECKLISTS · NOTICE DRAFTS

ZIRLANDIA MILKOVIC



THE FIRST 24 HOURS of a Cyberattack

INCIDENT RESPONSE

A Practical Incident Response Guide for Small Businesses

ZIRLANDIA MILKOVIC

FOR SMALL BUSINESSES · NO IT TEAM REQUIRED

The First 24 Hours of a Cyberattack

A Practical Incident Response Guide for Small Businesses

© 2026 Zirlandia Milkovic. All rights reserved. No part of this book may be reproduced, stored or transmitted in any form without written permission, except for brief quotations in reviews and for printing the worksheets, checklists and the notice templates for your own business use.

NOT LEGAL ADVICE. This book is an educational guide to the cyber incident response and, where relevant, the EU General Data Protection Regulation (Regulation (EU) 2016/679). It is not legal advice, does not create a lawyer-client or consultant-client relationship, and does not take your individual circumstances into account. Reading it, following it or using its templates does not make a business secure or legally compliant and is not a certification or a guarantee of any outcome.

LAWS CHANGE. Data protection law, regulatory guidance, court decisions and national rules develop continuously. The book reflects the author's understanding as of its publication date (2026) and refers to official sources so that you can check what applies now. National laws, supervisory-authority guidance and sector rules differ between countries. Before you rely on anything here for a decision with real consequences, take advice from a qualified lawyer or data protection professional in the relevant country.

Product and company names (for example email, analytics, advertising and AI platforms) are the property of their respective owners and are used only as examples for identification and education. This independent book is not affiliated with, sponsored by or endorsed by any of them, and no product is recommended or certified as compliant.

Every person, business and incident described in the case studies and scenarios is fictional and was created to illustrate ideas. Any resemblance to real people or companies is coincidental.

Premium Edition 2026 · PDF with clickable contents, bookmarks and fillable worksheets

Contents

Note	A Note from the Author	5
01	The Day Everything Changes	6
02	Is This Really an Attack?	10
03	Hour Zero	14
04	Contain the Damage	18
05	Five Playbooks for Common Attacks	22
06	Preserve the Evidence	26
07	Scope the Incident	30
08	Escalation: Who to Call and When	34
09	Decide: Do You Have to Notify?	38
10	Notify and Communicate	43
11	Recover Safely	47
12	The 24-Hour Plan and Beyond	51
Bonus	Incident Toolkit	54
A–Z	Plain-English Glossary	59
Ref	Official Sources & Further Reading	60
Bio	About the Author	61

A Note from the Author

Why this book is about one day, and why you should read it before you need it.

Nobody forgets the moment. A message on screen says your files are locked. A customer phones to ask why you emailed them a new bank account number. Your website shows a page you did not build. The stomach drops, and in the next few minutes you will make choices that shape the next few months.

Most small businesses do not collapse because an attacker got in. Getting in is now routine. The damage comes afterwards: the machine switched off and its evidence lost, the password reset that warned the intruder, the backup left plugged in, the insurer called too late, the customers who heard the news from someone else.

The first 24 hours rarely decide whether you are attacked. They decide how much it costs you.

This guide is written for owners, managers and office leads who have no security team and no incident plan. It follows the day in order: the first hour, containing the damage, preserving evidence, working out what was touched, escalating to the right people, making the legal decisions and talking to everyone who needs to hear from you. It ends with recovery and a plan for the weeks after. At the back is a toolkit of fill-in sheets and drafts you can adapt.

> NOTE **How to use this book**
>
> **If you are under attack right now**, go straight to the Quick-Start card in Chapter 3 and the hour-by-hour plan in Chapter 12, then come back and read the rest. **If you are not**, read it once, fill in the contact card in the toolkit, and keep a printed copy somewhere you can reach when your laptop and email are down. An hour of preparation today is worth more than anything you can do on the day.

PART I · UNDERSTAND THE DAY

CHAPTER

01

The Day Everything Changes

Why the first 24 hours matter more than every day after them, and the five jobs that fill them.

IN THIS CHAPTER

- Why the first day decides the size of the damage
- The five jobs of the first 24 hours, in order
- The panic reflexes that turn an incident into a disaster
- How the legal clocks start running

It is 9:40 on a Tuesday. The owner of a twelve-person online shop finds that the order system will not load. Then a message appears on the office manager's screen: every file is encrypted, pay in cryptocurrency within 72 hours. Nobody has a plan. Someone suggests restarting the server. Someone else forwards the message to the whole team. Within the hour, three people have rebooted their computers, a supplier has been emailed from the compromised account, and the only clean backup is still connected to the network.

Nothing about this attack was unusually clever. Almost everything that made it worse happened *after* it began.

Why the first day matters

In the early hours an incident is small and fixable. Each hour without action gives an attacker more time to spread, copy more data and cover their tracks. Yet each hasty action risks destroying the evidence you will need, alerting the attacker or breaking systems you want to recover. The first day is a narrow path between doing too little and doing too much.



The first day in four numbers

GDPR IN PLAIN ENGLISH **The clock starts at awareness**

The 72 hours in Article 33 of the GDPR run from the moment you become **aware** that a personal data breach has occurred, meaning you have a reasonable degree of certainty that a security incident has compromised personal data. They do not run from the day the attacker first got in, which may have been weeks earlier. And they do not pause while you investigate.

The five jobs of the first 24 hours

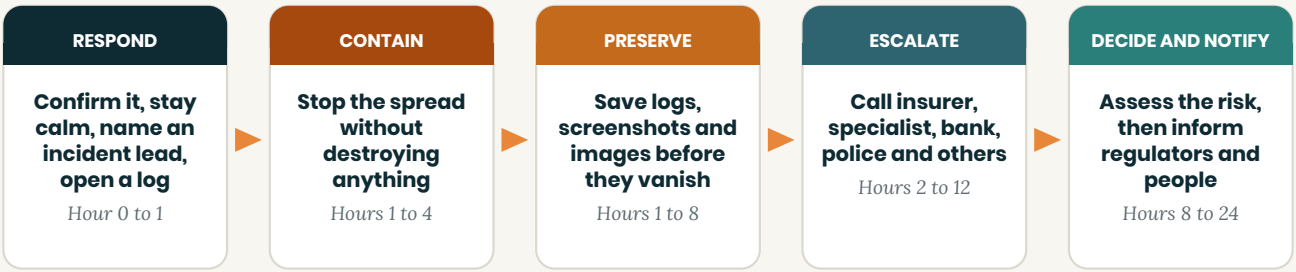


Figure 1 Five jobs, in this order

The jobs overlap. You will start preserving evidence while you are still containing, and you will make calls while you are still scoping. What matters is that nothing is skipped and that the order of priority never flips: stop the damage first, keep the proof second, tell people third.

Four panic reflexes to resist



Figure 2 What not to do

REAL-WORLD SCENARIO **Real-world scenario: the helpful reboot**

A small accounting firm notices one workstation behaving oddly. An employee reboots it "to see if that fixes it", and the next morning a colleague reinstalls the operating system. Two weeks later a client reports that their tax file was used to open a loan. The investigators cannot say which files were copied, because the logs and the machine's memory are gone. With no evidence either way, the firm must assume the worst and notify every client.

Regulators judge your response, not your bad luck

Regulators do not fine a business simply for being attacked. They ask whether you protected data sensibly beforehand and whether you handled the breach properly afterwards. Two widely reported UK cases show the stakes: in October 2020 the Information Commissioner fined British Airways £20 million after attackers accessed the personal data of over 400,000 customers and staff, and fined Marriott International £18.4 million over a breach exposing hundreds of millions of guest records. In both cases the final fines were well below the amounts first proposed, partly because the companies cooperated and had notified promptly.

Your risk is far smaller, but the lesson scales down: **fast action, honest cooperation and good records count in your favour.** That is what this book helps you build.

DO THIS NOW **Do this now**

Write down three names today: who decides what happens in an incident, who you call for technical help, and who talks to customers. If you cannot name them, you will lose your first hour finding out.

PART I · UNDERSTAND THE DAY

CHAPTER

02

Is This Really an Attack?

Spot the early warning signs and decide within ten minutes whether to start your incident process.

IN THIS CHAPTER

- The six most common ways small businesses are breached
- The warning signs that deserve a stop-and-check
- A ten-minute, five-question triage
- The difference between a security incident and a personal data breach

Not every odd email is an attack, and not every attack touches personal data. But a business that shrugs at every warning will one day shrug at the real one. This chapter gives you a quick way to decide, in minutes, whether to start the incident process.

Six common starting points

01
PHISHING
A convincing email or text tricks someone into typing a password into a fake page or opening an infected file. Still the most common beginning.

02
ACCOUNT TAKEOVER
Someone signs in as an employee using a stolen or reused password, often where multi-factor authentication is off. Email and cloud accounts are favourite targets.

03
RANSOMWARE
Files are encrypted and a payment demanded. Many gangs also steal data first, so restoring a backup does not end the problem.

04
BUSINESS EMAIL COMPROMISE
An attacker reads your mail, then sends fake invoices or changed bank details in your name. Money and data both leave.

05
LOST OR STOLEN DEVICE
An unencrypted laptop, phone or USB stick goes missing. Not a hack, yet often a reportable breach.

06
SUPPLIER BREACH
A tool or service you rely on is hacked and your customers' data goes with it. You remain responsible for it.

Figure 3 How attackers usually get in

Warning signs

Treat any of the following as a reason to pause and check, and treat two at once as an emergency.

- Files that will not open, carry strange new extensions, or sit beside a note demanding payment.
- Colleagues or customers reporting emails from you that you never sent.
- Password-reset or sign-in alerts you did not trigger, or logins from unusual places or hours.
- New forwarding rules or filters in a mailbox that nobody created.
- Security software switched off, or unknown programs and administrator accounts.
- Your bank, a supplier or a payment provider warning you about suspicious activity.
- Your website changed, redirecting visitors, or flagged as dangerous by browsers.
- Your data turning up online, or a stranger quoting information they should not have.

The ten-minute triage

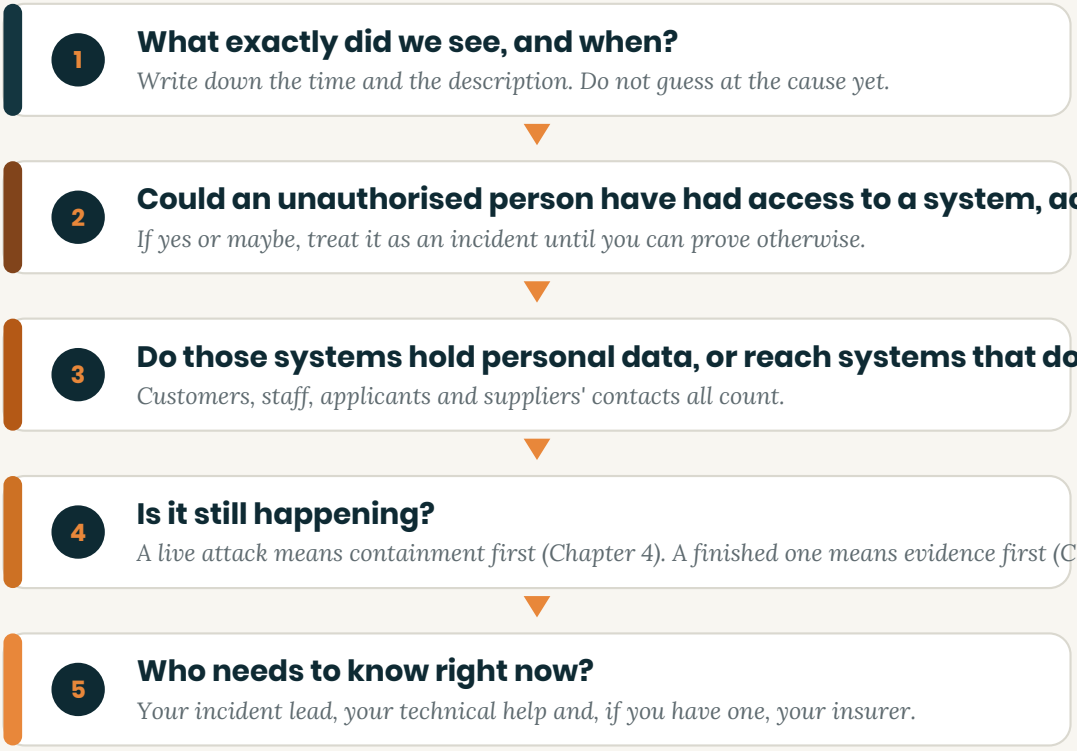


Figure 4 Ask these five questions, in this order

> **FOUNDER TIP** **When in doubt, open the log**
>
> Opening an incident log costs five minutes. Deciding "it was nothing" and being wrong costs days. If you are unsure, start the log and downgrade later. You can always close an incident, but you cannot get back the first hour you ignored.

Security incident or personal data breach?

The two terms overlap but are not the same, and the difference drives your legal duties.

SECURITY INCIDENT

- Any event that threatens the confidentiality, integrity or availability of your systems or information.
- Includes attacks that touched no personal data.
- Handled through your own response, insurer and technical help.
- No GDPR notification duty by itself.

PERSONAL DATA BREACH

- A security breach leading to accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data (Art. 4(12) GDPR).
- Includes lost devices, misdirected emails and locked-up records, not only hacking.
- Must be recorded in every case (Art. 33(5)).
- Must be reported to the authority unless unlikely to result in a risk to people (Art. 33).

Figure 5 Two terms, two sets of duties

WATCH OUT **Ransomware is usually a breach as well**

Even if nothing was copied, encrypting your customer records can make them unavailable, which counts as an **availability** breach. Whether you must notify depends on the risk to the people involved, for example how quickly you can restore and whether anyone depends on the data urgently. Treat it as a possible breach from the start.

PART II · RESPOND AND CONTAIN

CHAPTER

03

Hour Zero

The first sixty minutes: declare the incident, form a small team, open a log and make the first safe moves.

IN THIS CHAPTER

- A one-page Quick-Start for the first hour
- The four roles every incident needs, even in a team of three
- How to keep an incident log that protects you later
- What to tell staff, and what to keep inside the team

DO THIS NOW **Quick-start: the first hour**

1. Write down the time and what you saw. **2.** Tell your incident lead. **3.** Disconnect affected devices from the network (unplug the cable, turn off Wi-Fi) but do **not** switch them off. **4.** From a clean device, change passwords and sign out sessions for affected accounts. **5.** Call your technical help and your insurer's hotline. **6.** Start the incident log on paper or on a device that is not affected. **7.** Tell staff to stop using affected systems, delete nothing and keep quiet outside the team.

Step 1: Declare it

Someone has to say the words: "We are treating this as a security incident." Until that happens, everyone waits for someone else to act. Declaring does not mean you are certain. It means you have switched from ordinary work to incident mode, with one person in charge and a record being kept.

Step 2: Name four roles

A small business may have three people on the day. Assign roles anyway, because one person can hold two of them but nobody should hold none.



Figure 6 Four roles for the day

Step 3: Start the log

The log is the single most valuable document of the day. It shows regulators, insurers and lawyers that you acted sensibly, and it stops you from repeating work at hour nineteen when everyone is exhausted. Keep it on paper or on a device and account that are **not** affected. Write down facts, times and who did what, not opinions.

What every log entry contains

Field	Example
Date and time, with time zone	12 Nov 2026, 10:42 CET
What was seen or done	Forwarding rule found in finance mailbox and deleted
Who did it or reported it	Maria, office manager
Why	To stop copies of invoices leaving the business
Result or follow-up	Password reset; rule reappeared at 10:55, so the account is still compromised

Step 4: Make the first safe moves

Early actions should be reversible and should destroy nothing. Think of it as stopping the bleeding, not performing the surgery.

- **Isolate, do not power off.** Unplug network cables and turn off Wi-Fi on affected machines. Leave them running so their memory contents survive.
- **Secure the keys.** From a device you trust, reset passwords for email, administrator, finance and cloud accounts, and sign out all active sessions.
- **Turn on multi-factor authentication** wherever it is missing, starting with email and banking.
- **Protect the backups.** Make sure backup drives and cloud backup accounts are disconnected from affected systems.
- **Freeze payments.** Pause changes to bank details and any urgent payment requests until confirmed by phone.
- **Photograph the screen.** Ransom notes and error messages can vanish. Take a picture with a phone, with the clock visible if possible.

WATCH OUT **Use a clean channel**

If email or chat may be compromised, the attacker may read your response plan. Move the team to phone calls, text messages or a new group created from a trusted device, and tell everyone which channel to use.

Step 5: Tell your people

Staff will notice something is wrong within minutes. Tell them early, briefly and calmly, and give them one place to take questions. A good first message fits on a card.

> *"We have a security problem. Please stop using the affected systems, do not delete or forward anything, do not discuss it outside the company, and send every question to the incident lead."*

Avoid blame and speculation. If someone clicked a link, thank them for reporting it. People who fear punishment hide mistakes, and hidden mistakes are the expensive ones.

GOOD PRACTICE **Your first-hour scorecard**

By minute 60 you should have: an incident lead named, a log open, affected devices isolated, key accounts secured, help and insurer called, and staff briefed. Anything still missing goes to the top of the list for hour two.

PART II · RESPOND AND CONTAIN

CHAPTER

04

Contain the Damage

Hours one to four: stop the attacker spreading while keeping every option for investigation and recovery.

IN THIS CHAPTER

- The difference between containing, removing and recovering
- A containment checklist that is safe for most businesses
- How to decide what to isolate first
- What to do about backups, payments and suppliers

Containment means limiting how far the attacker can go and how much harm they can do, while preserving the ability to investigate and recover. It comes before cleaning up. The classic beginner's mistake is to rush to "fix" things, which usually means erasing the traces and leaving the door open.

Three phases, not one

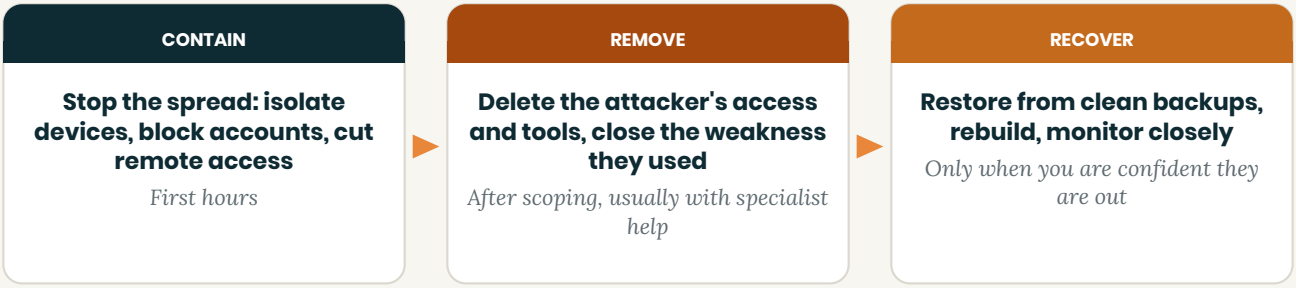


Figure 7 From containment to recovery

> **WATCH OUT** **Do not recover too early**
>
> Restore systems while the attacker still has access and they simply encrypt or steal again. Recovery begins only when you understand how they got in and have closed that route.

What to isolate first

You cannot isolate everything at once, and trying to will stop the business and bury you in work. Rank by how much harm each system can do if the attacker keeps it.

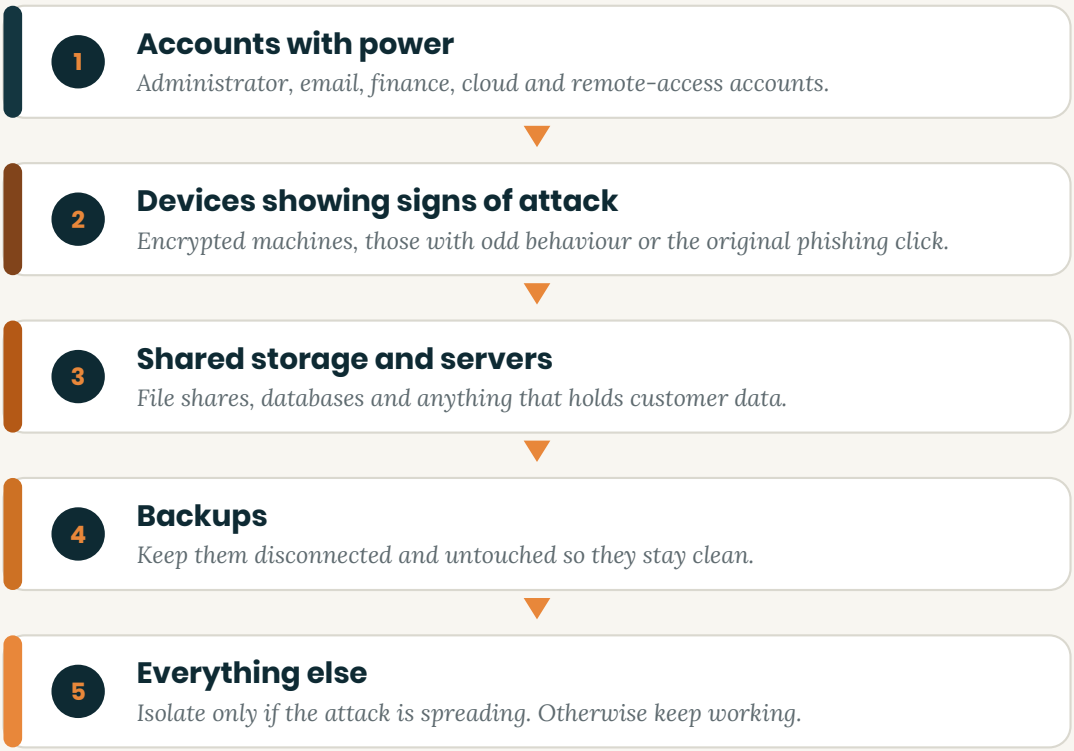


Figure 8 Containment priority, from most urgent

The first-day containment checklist

FIRST-DAY CONTAINMENT

- [ ] Affected devices disconnected from the network (cable out, Wi-Fi off) but still powered on.
- [ ] Passwords reset for affected accounts, starting with administrators, email and finance, from a clean device.
- [ ] Active sessions and tokens revoked, and multi-factor authentication enabled or reset.
- [ ] Mailbox rules, forwarding addresses, delegated access and connected apps reviewed; unknown ones removed.
- [ ] Remote-access tools, VPN accounts and shared logins disabled until verified.
- [ ] Backups checked and disconnected from the network so they cannot be encrypted.
- [ ] Payments and bank-detail changes frozen until confirmed by phone.
- [ ] Staff told which systems to avoid and which clean channel to use.

Watch the attacker's reaction

Attackers who realise they are discovered sometimes hurry: they encrypt everything, delete logs or publish stolen data. If you can, contain in one coordinated sweep rather than piece by piece, and do the quiet things (preserving logs, listing accounts) before the loud ones (password resets, account locks). Your technical help or insurer's responder can advise on timing.

Backups: the quiet priority

Attackers increasingly hunt for backups first, because without them you are more likely to pay. Check three things at once: whether backups exist, whether they are offline or otherwise protected from deletion, and whether the most recent ones may already contain the attacker's tools. Keep at least one known-good backup physically disconnected until recovery begins.

> **FOUNDER TIP** **The three-copy test**
>
> A resilient setup keeps three copies of important data on two different kinds of storage, with one copy kept offline or immutable. If you cannot say today where your offline copy is, make that your first improvement after this incident.

Suppliers and processors

If the attack came through a supplier, or if a supplier holds your data, you need answers fast. Under the GDPR your processors must tell you about breaches without undue delay, and you remain responsible for your customers' data. Call them rather than email, and ask the questions in the table below.

What to ask a supplier that has been breached

Question	Why it matters
When did it start and when was it found?	Sets your own timeline and shows whether notice was prompt
Which of our data was affected, and how many records?	Drives your risk assessment and any notices
Was the data encrypted or readable?	Changes the risk to the people involved
Has the attacker been removed, and how do you know?	Tells you whether the data is still exposed
What are you telling regulators, and what do you need from us?	Avoids contradicting each other

PART II · RESPOND AND CONTAIN

CHAPTER

05

Five Playbooks for Common Attacks

Step-by-step first responses for ransomware, email takeover, website compromise, lost devices and fake-invoice fraud.

IN THIS CHAPTER

- What to do in the first hour for each of five common attacks
- What to preserve and what to avoid in each case
- When a playbook tells you to escalate immediately
- How to adapt a playbook to your own tools

The general rules of the last two chapters apply to every attack. These playbooks add the details that differ. Each one is deliberately short: use it as a prompt for the person doing the work, not as a replacement for professional help.

Playbook 1: Ransomware

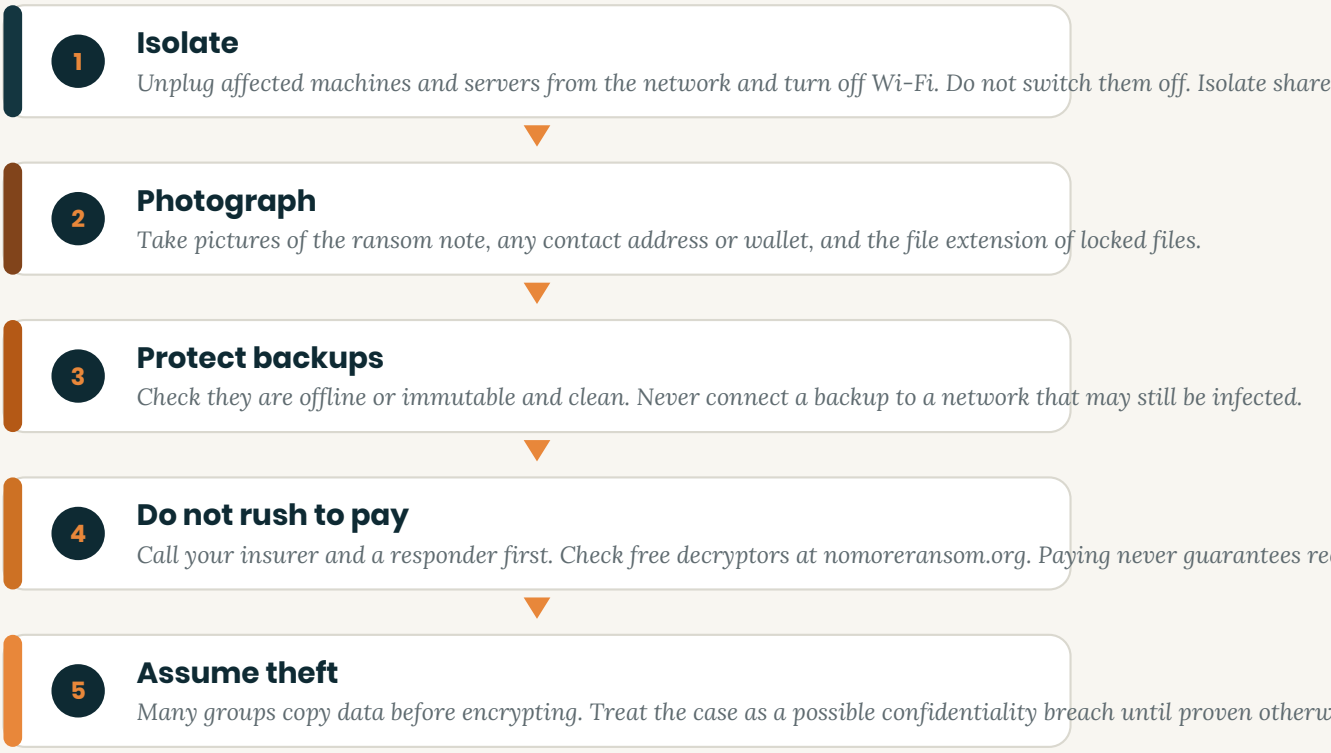


Figure 9 When files are encrypted and a ransom note appears

Playbook 2: Email or cloud account takeover

- From a trusted device, reset the password and sign out every session. Turn on multi-factor authentication.
- Look for forwarding rules, filters, new devices, newly authorised apps and changed recovery details.
- Export the sign-in history to see when and from where the attacker first appeared.
- Warn colleagues, customers and suppliers who may have received malicious messages, using a clean channel.
- Check every other account that used the same or a similar password, and change those too.

REAL-WORLD SCENARIO **Real-world scenario: the invisible rule**

A design agency resets a director's password after a phishing scare and thinks it is done. Weeks later a client pays an invoice to the wrong account. The attacker had created a hidden rule that copied incoming invoices to an outside address and was still editing bank details. A password reset alone does not remove rules, app permissions or stolen session tokens.

Playbook 3: Website or online shop compromise

- Take the site offline or put up a maintenance page. Visitors typing card details into a compromised checkout are the biggest risk.
- Before cleaning, take a full copy of the files, database and server logs, and note the time.
- Change hosting, admin, database and payment-provider credentials, and revoke old API keys.
- Contact your payment provider quickly if checkout pages or card data may be involved. Contracts often require immediate notice.
- Restore from a known-clean backup, update every plug-in and theme, and remove accounts you do not recognise before going back online.

Playbook 4: Lost or stolen device

- Note what the device was, when and where it disappeared and who had it last.
- Use remote lock or wipe if available. Record whether the device was encrypted, because that can greatly lower the risk to people.
- Revoke the user's sessions, change their passwords and remove the device from your accounts.
- List the personal data it could reach, including synced email and cloud files.
- Report theft to the police and keep the reference number for insurers and regulators.

GDPR IN PLAIN ENGLISH **Encryption can change the answer**

If lost data was strongly encrypted and the key was not exposed, the data may be unintelligible to anyone who obtains it. That can mean no high risk to the people concerned, and the duty to tell them under Art. 34(3)(a) GDPR may not apply. Record the evidence that the device was encrypted at the time.

Playbook 5: Fake-invoice or payment fraud

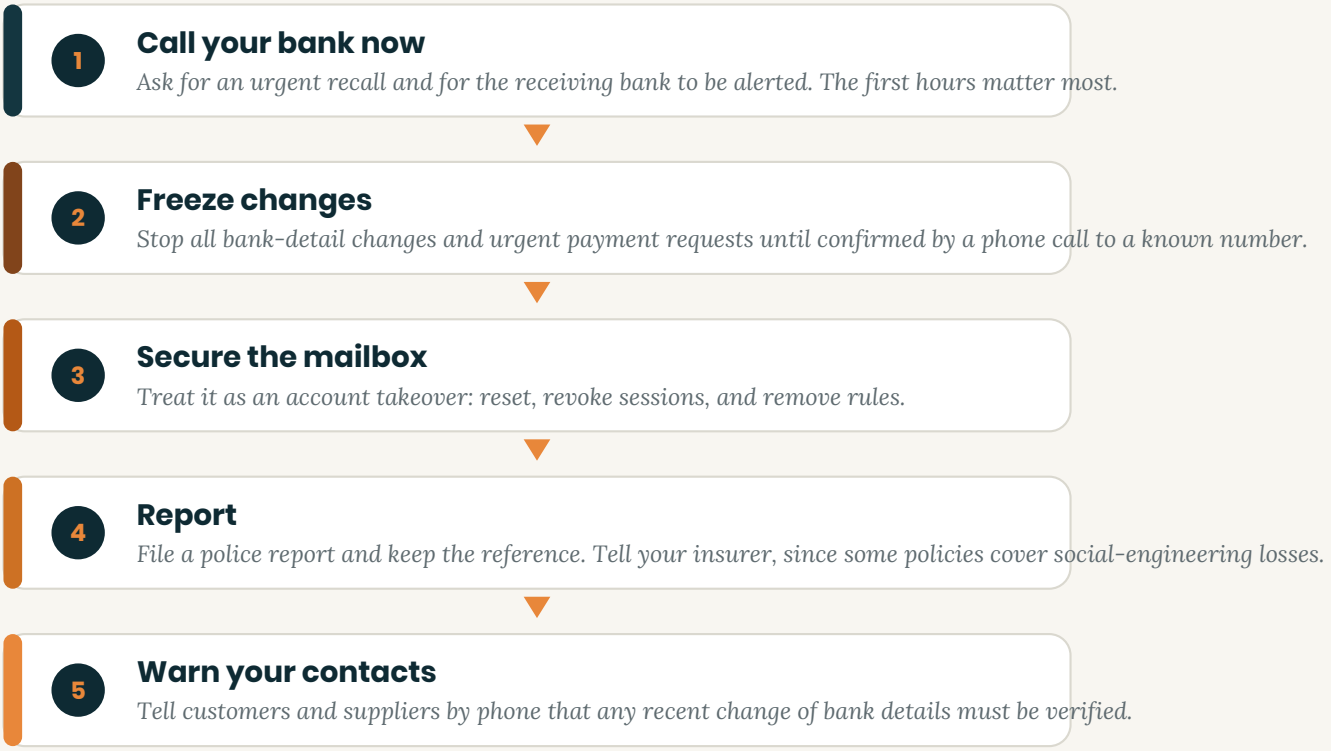


Figure 10 When money may already have left

FOUNDER TIP **Phone numbers beat email**

In any payment-fraud situation, verify by calling a number you already had before the incident, not one from the suspicious message. It is the cheapest control there is.

PART III · INVESTIGATE AND ESCALATE

CHAPTER

06

Preserve the Evidence

Hours one to eight: save the proof before it disappears, and handle it so it can be trusted.

IN THIS CHAPTER

- Why evidence matters for regulators, insurers, police and your own defence
- What to save first, ranked by how fast it disappears
- A simple chain-of-custody habit
- When to bring in a forensic specialist

Evidence answers the questions everyone will ask: how did they get in, what did they touch, what did they take, and when did it stop? Regulators, insurers, lawyers, customers and the police all want those answers. Without evidence you must assume the worst, notify more people and defend yourself with nothing.

Why it matters beyond the technical

The GDPR's accountability principle (Art. 5(2)) requires you to be able to demonstrate compliance. For breaches, Article 33(5) goes further: you must **document every personal data breach**, including its facts, its effects and the action taken, so the authority can verify what you did. Insurers will ask for the same material when you claim, and a police report is only as good as what you can show.

The order of volatility

Different evidence disappears at different speeds. Save the fastest-fading first.

Order of volatility: save the top first

Priority	What	Why it is urgent
1	Live state	Open sessions, running programs and memory of affected machines. Lost the moment you power off.
2	Logs	Email, firewall, VPN, cloud and application logs. Often overwritten within days or weeks.
3	Disks and files	Affected machines, ransom notes, suspicious files and malware samples.
4	Messages	Phishing emails with full headers, attacker messages, call recordings.
5	Paperwork	Your own notes, screenshots, timelines and decisions.

The evidence checklist

PRESERVE BEFORE YOU CLEAN

- [ ] Photos or screenshots of ransom notes, error messages and pop-ups, with the date and time visible.
- [ ] Original suspicious emails saved in full, with headers, not just forwarded copies.
- [ ] Sign-in logs, admin audit logs and mailbox audit logs exported from email and cloud providers.
- [ ] Firewall, VPN, web server and application logs copied to a safe place.
- [ ] A list of affected devices with make, serial number, user and location.
- [ ] Disk images or memory captures made by a specialist where the incident is serious.
- [ ] Backups from before and after the incident kept untouched.
- [ ] Your incident log and a record of every decision.

WATCH OUT **Logs have a short shelf life**

Many cloud services keep detailed logs for only 30, 90 or 180 days, and some plans keep far less. Export them on day one, even if you do not yet know what you are looking for.

A simple chain of custody

Chain of custody sounds formal, but the habit is simple: for each item, record **what** it is, **where** it came from, **who** collected it, **when**, and **where it is now**. Store copies on encrypted media, keep originals untouched, and write down every time someone hands an item to someone else. If anyone later questions whether evidence was altered, the record answers it.

Evidence log example

Item	Source	Collected by	Date and time	Stored at
Ransom note screenshot	Finance PC	Maria	12 Nov 10:45	Encrypted USB 1, safe
Mailbox audit log, 30 days	Email admin portal	Jan	12 Nov 11:20	Encrypted USB 1, safe
Phishing email with headers	Maria's mailbox	Jan	12 Nov 11:35	Encrypted USB 1, safe
Disk image, finance PC	Finance PC	External responder	12 Nov 14:10	Responder vault, copy ref. 4

When to call a specialist



Figure 11 Signs you need forensic help

FOUNDER TIP **Check your insurance today**

Many cyber policies include a 24-hour incident hotline, approved forensic firms and legal support. Using someone else may void cover. Find the policy number and hotline and put them on your contact card before you need them.

PART III · INVESTIGATE AND ESCALATE

CHAPTER

07

Scope the Incident

Hours four to eight: work out what was touched, build a rough timeline and keep a fact sheet you update every few hours.

IN THIS CHAPTER

- The questions that define the scope of an incident
- How to build a timeline from imperfect facts
- What to do when you cannot be certain
- A fact sheet that becomes your single source of truth

By hour four or five the worst fires are out, and you face the question everything else depends on: **what did the attacker reach?** You will not have the full answer for days. You need enough of it to make decisions, and a method for updating it as facts arrive.

The nine scoping questions

1. **How did it start?**
   Phishing, stolen password, unpatched system, lost device, supplier? Note the likeliest entry point and how sure yo
2. **When did it start and when was it found?**
   These are different times. The first may be weeks before the second.
3. **Which systems and accounts were affected?**
   List servers, laptops, mailboxes, cloud tools, websites and admin accounts.
4. **Is the attacker still active?**
   New logins, new alerts or changing files mean yes.
5. **What data sat on those systems?**
   Customer lists, staff files, invoices, ID copies, health or payment data.
6. **Whose data is it?**
   Customers, employees, applicants, suppliers' contacts, children, patients.
7. **Was it only accessed, or also copied, changed or deleted?**
   Copying is the hardest to prove. Look for large transfers and unusual exports.
8. **How many people and records?**
   A best estimate with a range is better than waiting for an exact number.
9. **What is the likely harm to them?**
   Fraud, phishing, embarrassment, discrimination, physical risk.

Figure 12 Answer what you can, mark the rest "unknown"

Build a timeline

A timeline turns scattered facts into a story you can reason about and explain. Start with what you know for certain and add what the logs show. Note the source of each entry and mark guesses as guesses.

Day -9 — **Phishing email received**
A staff member enters a password on a fake login page. The attacker signs in that evening.

Day -8 — **Silent monitoring**
The attacker sets a hidden forwarding rule and reads client email for several days.

Day 0, 09:15 — **Fake invoice sent**
A client receives altered bank details and phones the agency to check.

Day 0, 09:40 — **Incident declared**
The owner opens the log and isolates the account. Awareness: 09:40.

Day 0, 14:00 — **Scope understood**
Audit logs show nine days of access and forwarding from eleven mailboxes.

Figure 13 Example: a small agency under attack

> **GDPR IN PLAIN ENGLISH** **Aware does not mean certain**
>
> The EDPB's breach guidelines say you are "aware" when you have a **reasonable degree of certainty** that a security incident has compromised personal data. A short initial investigation is allowed so you can establish this, but it must start at once and not drift. Once you are reasonably sure, the clock is running.

When you cannot be sure

Often you will not know whether data was copied. Do not stall. Reason from what you can show and be honest about what you cannot.

- **Assume the worst credible case** for planning and decisions, and say so in your records.
- **Look for the opposite proof.** Logs showing that nothing left the network, or that data was encrypted, can lower the risk.
- **Record the uncertainty.** "Unknown, investigating, update expected by Friday" is an acceptable entry. Silence is not.
- **Revisit every few hours** as new facts arrive, and keep every earlier version of the fact sheet.

WORKSHEET

Incident fact sheet

Update this every few hours and date each version. It becomes the basis of your breach assessment and any notice.

Date and time we became aware

How the incident was detected

Systems and accounts affected

Types of personal data involved

Categories of people affected (customers, staff, others)

Approximate number of people and records

Was the data encrypted, copied, altered or deleted?

Is the attacker still active?

Actions taken so far

Still unknown

PART III · INVESTIGATE AND ESCALATE

CHAPTER

08

Escalation: Who to Call and When

Hours two to twelve: bring in the right people at the right time, from your insurer to the police.

IN THIS CHAPTER

- A severity scale that tells you how far to escalate
- Who to call, in what order, and what to have ready
- What to expect from an insurer, a responder and the police
- How escalation connects to your legal duties

Small businesses tend to escalate too late, because calling for help feels like admitting failure or spending money. In practice the opposite is true: the earlier the right person joins, the cheaper the incident. Escalation is not a single phone call. It is a ladder, and you climb it as the facts demand.

How serious is it?

Level 1	Level 2	Level 3	Level 4
Contained scare	**Limited incident**	**Serious incident**	**Crisis**
No personal data affected, or a small local issue easily fixed. Log it and learn from it.	Small amount of data or low risk to people. Record and assess it. Notification probably not needed.	Sensitive data, many people, criminal intent or loss of money. Expect to notify the authority and perhaps individuals.	The attack is ongoing, data theft is large or the business is down. Full response with specialists and legal advice.

Figure 14 Quick severity scale

The escalation ladder

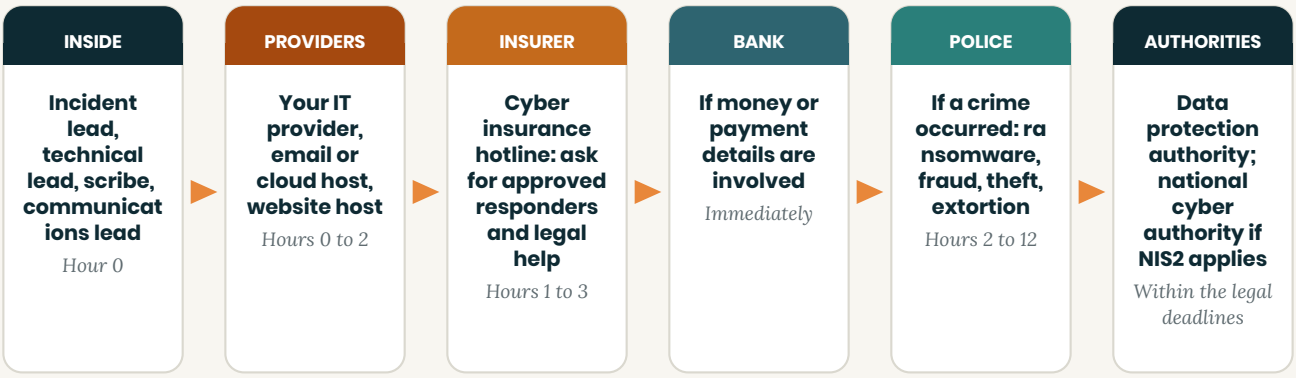


Figure 15 Who joins, and when

What to have ready before you call

YOUR CALL SHEET

- [ ] Your business name, address, policy number and the name of the person calling.
- [ ] The time you noticed the problem and a two-sentence description of what you saw.
- [ ] Which systems, accounts or sites are affected and what you have already done.
- [ ] What kinds of personal data might be involved and roughly how many people.
- [ ] Whether the attacker appears to be still active.
- [ ] A phone number where you can be reached at any hour.

What each party does for you

Who does what

Who	What they bring	What they will ask
Cyber insurer	Hotline, approved responders and lawyers, sometimes cost cover	Policy number, timeline, what you have already done
Incident responder	Containment advice, forensic imaging, scope and root cause	Access to logs and systems, the evidence you have gathered
Police	Crime reference number, sometimes help with fraud recalls	Description, dates, losses and copies of messages
Your bank	Payment recall and flagging of accounts	Transaction details, recipient account, timings
Payment provider	Guidance if card data may be affected	Time of exposure and affected sites or devices
Lawyer or adviser	Advice on notification duties and contracts	Your fact sheet and the draft notices

WATCH OUT **Check before you pay or negotiate**

If attackers demand money, do not negotiate or pay before speaking to your insurer, a specialist and the police. Law enforcement agencies advise against paying, because payment funds crime and gives no guarantee of recovery, and in some circumstances paying may breach sanctions rules.

Other reporting duties on the same day

Beyond the GDPR

Who	When to consider	Notes
Your cyber insurer	Immediately	Late notice can reduce or void cover
Police or national cybercrime unit	When a crime has occurred	A reference number helps insurers and banks
National cyber authority or CSIRT	If NIS2 applies to your sector and size	Early warning within 24 hours, fuller notification within 72 hours, final report within one month
Payment provider or card schemes	If card data may be involved	Contracts often require immediate notice
Customers and partners	If contracts promise notice	Many business contracts require 24 to 72 hours
Sector regulators	Finance, health, telecoms and others	Rules differ by sector and country

NOTE **Does NIS2 apply to you?**

The NIS2 Directive covers many medium and large businesses in sectors such as energy, transport, digital infrastructure, manufacturing and food, with national laws setting the details. Very small firms are often outside it, but you may be bound through a customer contract. Ask your adviser now rather than during the incident.

PART IV · DECIDE AND COMMUNICATE

CHAPTER

09

Decide: Do You Have to Notify?

Hours eight to twenty-four: assess the risk to people and choose between recording, informing the authority and informing individuals.

IN THIS CHAPTER

- The three types of personal data breach
- How to assess risk to people in plain steps
- The three possible outcomes and what each requires
- How to document your decision so you can defend it

This is the legal centre of the first day. Take the facts from Chapter 7 and answer three questions in order. Write down both the answers and the reasons, because the reasoning is what a regulator will examine.

Question 1: Is it a personal data breach?

Article 4(12) defines a personal data breach as a breach of security leading to the **accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data**. The EDPB groups these into three types, and one incident can be several at once.

- **Confidentiality breach:** someone without authority gets access to the data or a copy of it.
- **Integrity breach:** data is altered without authority.
- **Availability breach:** data is lost, destroyed or temporarily inaccessible, for example through ransomware.

Question 2: How risky is it for the people involved?

The risk that matters is the risk to the **rights and freedoms of individuals**, not to your business. Weigh the factors below, and when in doubt assume the higher level.

Factors that raise or lower the risk

Factor	Higher risk	Lower risk
Type of breach	Deliberate theft or leak	Brief loss of access with quick restore
Nature of the data	Health, financial, ID documents, passwords, children, special categories	Business contact details already public
Ease of identifying people	Names with addresses or national numbers	Properly encrypted or pseudonymised data
Number of people	Thousands	A handful
Severity of consequences	Fraud, discrimination, physical harm	Minor inconvenience
Who has the data	Criminals, publishers, unknown parties	A trusted recipient who deleted it
Vulnerable people	Children, patients, people in weak positions	General business contacts

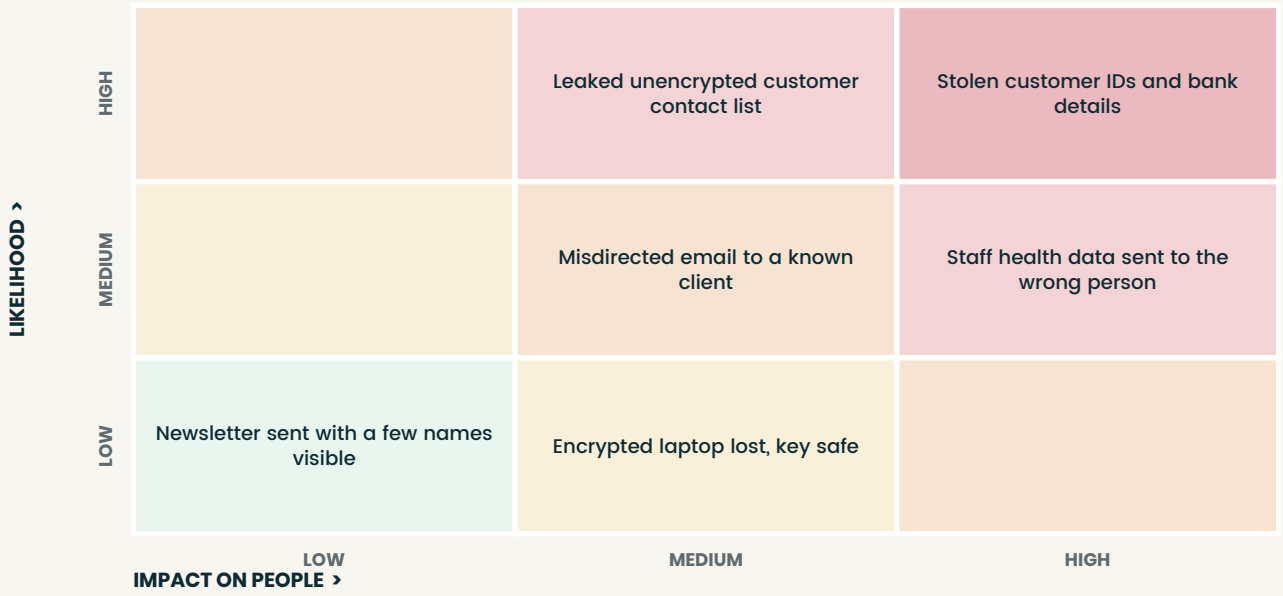


Figure 16 Likelihood of harm against severity for people

Question 3: What must I do?

1	**Is personal data involved in the incident?**	YES Continue to the next question	NO No GDPR breach duty. Keep the incident record.
2	**Is the breach unlikely to result in a risk to people?**	YES Record it internally (Art. 33(5)) and write your reasoning down. No notification needed.	NO Notify the supervisory authority within 72 hours (Art. 33).
3	**Is the breach likely to result in a high risk to people?**	YES Also tell the affected people without undue delay (Art. 34).	NO Authority only. Keep the reasoning.

Figure 17 Which duties apply?

WHAT THE LAW REQUIRES **Three outcomes**

Unlikely to result in a risk: document it internally, no notification. **Likely to result in a risk:** notify the supervisory authority within 72 hours. **Likely to result in a high risk:** notify the authority and the affected individuals without undue delay. When unsure, lean towards notifying: the penalty for failing to notify is usually worse than the cost of an unnecessary report.

When you need not tell individuals

Article 34(3) lists three situations in which you do not have to inform individuals even when the risk is high: the data was **unintelligible** to anyone not authorised, for example strongly encrypted; you have taken **subsequent measures** that mean the high risk is no longer likely; or contacting each person would involve **disproportionate effort**, in which case you must use a public communication instead. The authority can also order you to inform people.

Write the decision down

Whatever you decide, record who decided, when, on what facts and for what reasons, ideally with a second reviewer. A decision not to notify is acceptable if reasoned and recorded, and is a serious problem if it was merely a hunch.

WORKSHEET

Breach risk assessment

Complete this at hours 8 to 12, and again when facts change. Keep every version.

Type(s) of breach (confidentiality, integrity, availability)

Data categories involved

Approximate number of people

Likelihood of harm (1 to 3) and why

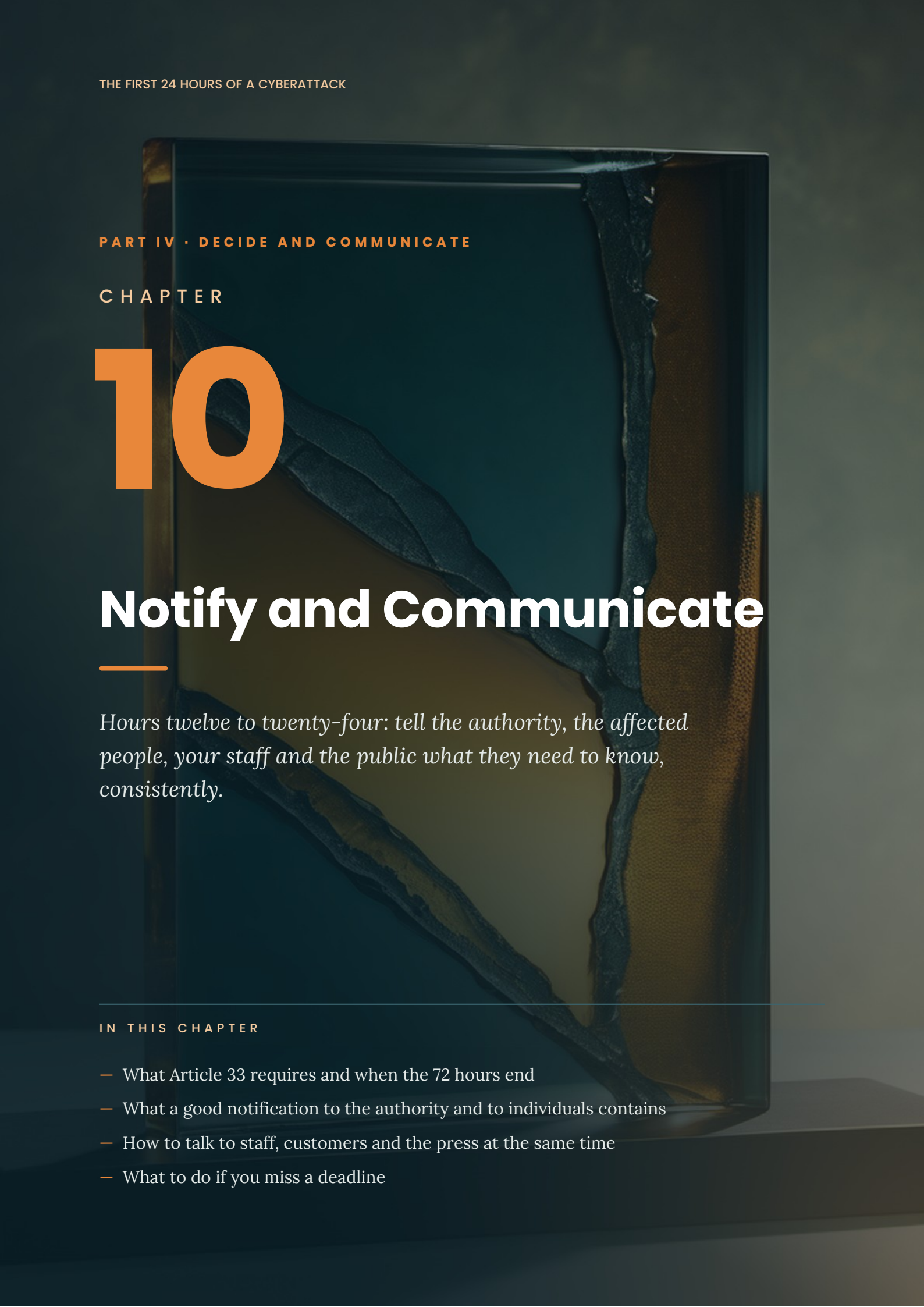
Severity of harm (1 to 3) and why

Decision: record only / notify authority / notify authority and individuals

Reasoning in two or three sentences

Assessed by and second reviewer

Date and time



PART IV · DECIDE AND COMMUNICATE

CHAPTER

10

Notify and Communicate

Hours twelve to twenty-four: tell the authority, the affected people, your staff and the public what they need to know, consistently.

IN THIS CHAPTER

- What Article 33 requires and when the 72 hours end
- What a good notification to the authority and to individuals contains
- How to talk to staff, customers and the press at the same time
- What to do if you miss a deadline

Notifying the authority

If the breach is likely to result in a risk to people, you must notify the competent supervisory authority **without undue delay and, where feasible, within 72 hours of becoming aware**. If you are later than that, you must give reasons for the delay. The 72 hours are calendar hours, so weekends and holidays count. Most authorities provide an online form.

Required content (Art. 33(3))

Element	What to include
Nature of the breach	What happened, the type of breach, categories and approximate number of people and records
Contact point	Name and details of your DPO or another person who can give more information
Likely consequences	What could happen to those affected, such as fraud, phishing or loss of confidentiality
Measures taken or proposed	What you did to contain it and limit harm, and what you plan next

FOUNDER TIP **Send what you have, then add**

Article 33(4) allows information to be provided in phases when it cannot all be given at once. A first report saying "initial notification, investigation ongoing, update by [date]" is far better than silence while you wait for certainty.

If you miss the deadline

Notify as soon as you can and explain why you were late. Late notification with an honest reason is treated far better than none. Do not backdate documents or change your log to appear on time: that turns a compliance problem into a trust problem.

Telling the affected people

Where the risk is high, Article 34 requires you to tell the individuals directly and without undue delay, in clear and plain language. They can only protect themselves, by changing passwords, watching accounts or staying alert to scams, if they know.



Figure 18 What people need to know

Customer notification (draft)

```
Subject: Important information about your personal data

Dear [Name],

We are writing to tell you about a security incident that affected some of the personal data we
hold about you.

What happened: On [date] we discovered that [short description, e.g. an unauthorised person gain
ed access to our customer system].
What information was involved: [list the data, e.g. your name, email address and order history].
 [State clearly whether payment card details or passwords were or were not included.]
What we have done: We have [contained the incident, engaged security specialists, informed the d
ata protection authority].
What you can do: [e.g. change your password and any account where you reuse it; be careful with
unexpected emails or calls that mention us; check your bank statements].
Who to contact: [name, email, direct phone number]. We are sorry this happened and we will keep
you informed.

[Name, role, business]
```

Staff, partners and the public

Staff

Tell them early, briefly and often. Explain what to do and not do, name one person for questions and promise regular updates even when the update is "no change". Silence invites rumour.

Customers and partners

Decide who is affected first, then tell people in order of risk and obligation. Do not notify everyone on a hunch. Keep a holding statement ready for anyone who asks before you are ready.

Holding statement (draft)

```
We have identified a security incident affecting some of our systems. We are investigating with specialists and have taken steps to contain it. We will contact anyone whose personal data is affected directly, as soon as we know more. If you have concerns, please contact [name, phone, email].
```

Press and social media

Appoint one spokesperson. Say what you know and what you are doing, never speculate about attackers or numbers, and never contradict what you told the authority.

WATCH OUT **Consistency is a legal risk**

Your notice to the authority, your message to customers and your public statement must tell the same story. Mismatched numbers or timelines can look like concealment. Keep one fact sheet as the single source of truth, and have the incident lead approve every outgoing message.

PART V · RECOVER AND LEARN

CHAPTER

11

Recover Safely

Days one to seven: rebuild in the right order, prove the attacker is gone and watch for a second strike.

IN THIS CHAPTER

- How to remove the attacker's access before restoring
- A safe order for rebuilding systems
- How to verify a backup before you trust it
- What to monitor in the weeks after

Recovery is where well-handled incidents are won or lost. Rushing back to normal feels productive, but a business restored on top of a live intrusion will simply be hit again, often within days. Recover on purpose, in a deliberate order, and with checks at each step.

Before you restore anything

READY-TO-RECOVER GATE

- [ ] You understand, or have a credible theory of, how the attacker got in.
- [ ] That entry route is closed: patched, disabled or protected with multi-factor authentication.
- [ ] All passwords, keys and tokens that the attacker could have seen have been changed.
- [ ] Unknown accounts, scheduled tasks, remote tools and forwarding rules have been removed.
- [ ] Evidence you need has been copied and stored safely.
- [ ] The backup you plan to use predates the intrusion and has been checked for malware.

A safe order of rebuild

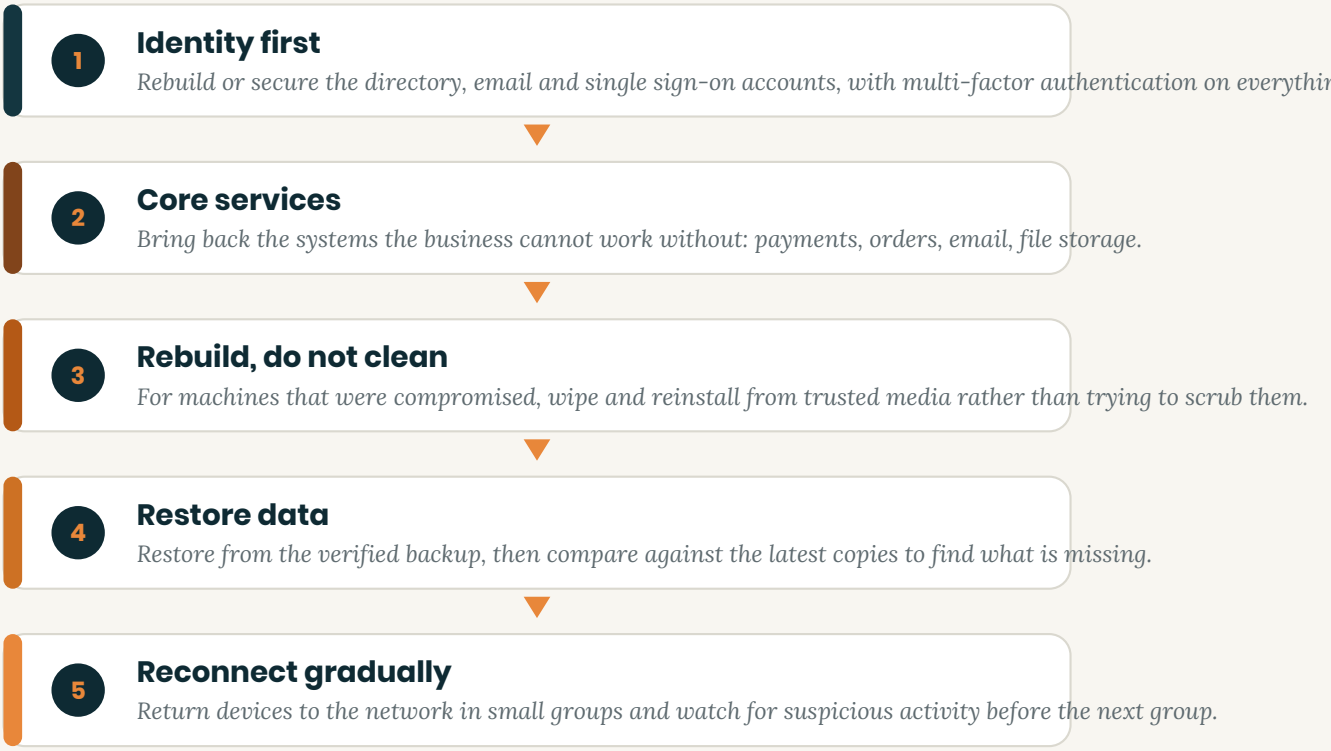


Figure 19 Restore in this order

Trust, but verify the backup

A backup you have never restored is a hope, not a backup. Before you rely on one, test it on an isolated machine: does it open, is it complete, does it contain the attacker's tools or a hidden mailbox rule? If the attacker was inside for weeks, the newest backup may be infected, and you may need an older one and accept the data loss.

Watch for the second strike

- Enable alerts for new sign-ins, new admin accounts, forwarding rules and large downloads.
- Keep the elevated logging you switched on for at least thirty days.
- Expect phishing aimed at your customers using stolen data, and warn them.
- Check dark-web and breach-notification services for your domain and staff addresses.
- Review accounts again after a week, because attackers often return through a missed door.

REAL-WORLD SCENARIO **Real-world scenario: back in a day, hit again in four**

A small logistics firm restored its servers from backup within a day and was proud of it. Nobody had checked how the attacker entered: an exposed remote-desktop port with a weak password. Four days later the same group was back. The second attack cost more than the first because customers no longer trusted the company's assurances.

Count the cost

Keep a simple record of the costs: staff time, specialist fees, lost sales, refunds, legal advice, notification costs and equipment. You need it for insurance, for management and for deciding what to improve. It also shows, plainly, what an hour of preparation would have saved.

PART V · RECOVER AND LEARN

CHAPTER

12

The 24-Hour Plan and Beyond

Everything in this book on one timeline, a plan for the weeks after, and ten steps to be ready next time.

IN THIS CHAPTER

- A complete hour-by-hour plan for the first day
- How to run a night or weekend incident
- A blameless review that makes you stronger
- Ten steps to prepare for the next one

The plan on one page

Hour 0 to 1
Respond
Declare the incident, name four roles, open the log outside affected systems, isolate devices, secure key accounts, make the first calls.

Hour 1 to 4
Contain
Work through the containment checklist, protect backups, freeze payments, start capturing evidence and exporting logs.

Hour 4 to 8
Scope
Answer the nine scoping questions, build the timeline, complete the first fact sheet.

Hour 8 to 12
Assess
Run the breach risk assessment with a second reviewer and decide: record only, authority, or authority and individuals.

Hour 12 to 18
Prepare
Draft the authority notification and any customer notice. Inform insurer, partners, bank and police as needed.

Hour 18 to 24
Notify and stabilise
Submit the notification if required, brief staff, plan day two, hand over rested and begin recovery planning.

Figure 20 The first 24 hours

> **GDPR IN PLAIN ENGLISH** **You do not need to finish in a day**
>
> The GDPR gives you up to 72 hours for the authority notification, not 24. This plan aims to reach a decision within the first day so that you have the remaining time to send, check and correct. Use that time. A careful notice at hour 40 beats a rushed, wrong one at hour 20.

Nights, weekends and tired people

Attackers love Friday evenings. If the incident runs through the night, plan shifts: nobody should make legal or technical decisions after twenty hours awake. Hand over with a five-minute written summary (what is done, what is running, what is next, what to avoid), and make sure the log is the handover document.

After the first day



Figure 21 Days two to thirty

Run a blameless review

Within two weeks, gather the people involved and ask four questions: What happened? What went well? What did we miss or do badly? What will we change, who will do it and by when? Keep the tone about systems and decisions, not people. A team that expects blame hides near-misses, and near-misses are your cheapest lessons.

Ten steps to be ready next time

PREPARE BEFORE THE NEXT INCIDENT

- [ ] Fill in the contact card and keep printed copies in two places.
- [ ] Turn on multi-factor authentication for email, banking, admin and cloud accounts.
- [ ] Keep one backup offline or immutable, and test a restore every quarter.
- [ ] Write down who holds the four incident roles and who stands in for them.
- [ ] Find your cyber insurance hotline and policy number, or decide whether you need cover.
- [ ] Keep software, plug-ins and devices updated, and remove accounts that are no longer needed.
- [ ] Encrypt laptops and phones, and enable remote lock and wipe.
- [ ] Teach staff to spot phishing and to report mistakes without fear of blame.
- [ ] Keep a breach register and a copy of the notice drafts from this book.
- [ ] Rehearse: spend one hour a year walking through a scenario with your team. Start with the one that would hurt most to be missing, and put a date next to it today.

BONUS

T

Incident Toolkit

Contact card, 24-hour tracker, evidence log, decision log, breach register and ready-to-adapt notices. Fill them in on screen or print them.

IN THIS CHAPTER

- A contact card for the people you will need
- A 24-hour action tracker
- An evidence log, decision log and breach register
- Draft notices for the authority, the owner and your customers

WORKSHEET

Incident contact card

Fill this in now. Print it and keep copies in two physical places. These sheets are educational templates, not legal advice: adapt them to your business and country.

Incident lead (name, mobile)

Deputy (name, mobile)

Technical help / IT provider (name, 24-hour number)

Privacy lead or DPO (name, mobile)

Communications lead (name, mobile)

Cyber insurer (policy number, incident hotline)

Lawyer or adviser (name, number)

Bank fraud contact

Data protection authority breach form (web address)

Police / cybercrime reporting contact

Key suppliers' emergency contacts

24-HOUR ACTION TRACKER

Hour	Action	Owner	Done at	Notes
e.g. 0 to 1	*Declare incident, open log*	*Incident lead*	09:40	*Log kept on paper*

EVIDENCE LOG

Item	Source	Collected by	Date and time	Stored at
e.g. Ransom note screenshot	*Finance PC*	*Maria*	*12 Nov 10:45*	*Encrypted USB 1*

DECISION LOG

Date and time	Decision	Made by	Reasons	Reviewed by
e.g. 12 Nov 12:30	*Isolate file server*	*Incident lead*	*Possible spread*	*Technical lead*

PERSONAL DATA BREACH REGISTER (ART. 33(5))

Date aware	Facts	Data and people affected	Effects	Actions taken	Authority told?	Individuals told?	Reasoning
e.g. 12 Nov 09:40	*Mailbox takeover*	*Client emails, about 120 people*	*Phishing risk*	*MFA, reset, rule removed*	*Yes, 13 Nov*	*Yes, 14 Nov*	*High risk: bank details*

Draft: notification to the supervisory authority

Authority notification (draft, Art. 33(3))

```
Initial / update notification no. [1]
Controller: [business name, address, registration no.]
Contact point: [name, role, email, phone]
Date and time the breach occurred (or estimate): [ ]
Date and time we became aware: [ ]
Nature of the breach: [confidentiality / integrity / availability; short description]
Categories and approximate number of people: [customers, staff... about N]
Categories and approximate number of records: [ ]
Likely consequences: [e.g. phishing, fraud, loss of confidentiality]
Measures taken or proposed: [containment, investigation, notice to individuals, extra protection
s]
Individuals informed? [yes / no / planned, date]
Cross-border implications: [other member states, if any]
Information still being investigated and expected update date: [ ]
Reason for delay (if more than 72 hours): [ ]
```

Draft: one-page summary for the owner

Management summary (draft)

```
What happened in one sentence: [ ]
Current status: [contained / under investigation / recovered]
Personal data affected: [ ]
People affected: [ ]
Our legal position: [record only / authority notified / authority and individuals]
Next deadline: [ ]
Decisions needed from you: [ ]
Costs so far and expected: [ ]
```

Draft: shift handover note

Handover note (draft)

```
Time of handover: [ ]       From: [ ]       To: [ ]
Done so far: [ ]
Running right now (do not disturb): [ ]
Next three actions: [ ]
Do not touch or do: [ ]
Waiting on: [who, what, expected when]
Latest version of the fact sheet: [location]
```

Plain-English Glossary

The terms you will meet on the way, in alphabetical order.

Awareness	The point at which you have a reasonable degree of certainty that a security incident has compromised personal data. It starts the 72-hour clock.
Availability breach	Personal data is lost or cannot be accessed, for example through ransomware or deletion.
Business email compromise	An attacker uses a hijacked or spoofed mailbox to trick people into paying or sharing data.
Chain of custody	The record of who held a piece of evidence and when, showing it was not altered.
Confidentiality breach	Someone without authority gets access to personal data or a copy of it.
Containment	Actions that limit how far an attack can spread, taken before cleaning up.
Controller	The organisation that decides why and how personal data is processed.
CSIRT	Computer Security Incident Response Team: a national or sector team that handles cyber incidents.
Data subject	The person the personal data is about.
DPO	Data Protection Officer: an independent adviser required in some organisations (Arts. 37 to 39).
Eradication	Removing the attacker's access and tools and closing the weakness they used.
High risk	A level of risk to people serious enough to require telling them directly (Art. 34).
Integrity breach	Personal data is changed without authority.
MFA	Multi-factor authentication: a second proof of identity, such as a code or app approval, in addition to a password.
NIS2	The EU directive on the security of network and information systems, with incident reporting duties for many medium and large organisations.
Personal data breach	A security breach leading to accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data (Art. 4(12)).
Phishing	A deceptive message that tricks someone into revealing credentials or installing malware.
Processor	An organisation that processes personal data on behalf of a controller.

Ransomware	Malware that encrypts files and demands payment, often combined with data theft.
Supervisory authority	The national data protection regulator, such as the CNIL in France.
Tabletop exercise	A talk-through of a made-up incident to test your plan.

Official Sources & Further Reading

Where the legal claims in this book come from, and where to check what applies today.

Always prefer the primary sources below to summaries, including this one. Web addresses change: if a link has moved, search the official site for the title shown. Guidance is updated regularly, so check for the latest version before relying on it.

Primary EU law (EUR-Lex)

- **General Data Protection Regulation (GDPR)**, Regulation (EU) 2016/679. Notably Art. 4(12) (personal data breach), Art. 5(2) (accountability), Art. 28 and 33(2) (processors), Art. 32 (security), Art. 33 (notification to the authority), Art. 34 (communication to individuals), Art. 82 (compensation) and Art. 83 (fines). eur-lex.europa.eu/eli/reg/2016/679/oj
- **NIS2 Directive**, Directive (EU) 2022/2555, on measures for a high common level of cybersecurity, including incident reporting. Applies through national laws: check yours.

Regulators and guidance

- **European Data Protection Board (EDPB)**, Guidelines 9/2022 on personal data breach notification under the GDPR (version 2.0, March 2023), and Guidelines 01/2021 on examples regarding personal data breach notification: edpb.europa.eu
- **Your national data protection authority**: most provide an online breach-reporting form and local guidance. Find yours on the EDPB website.
- **UK Information Commissioner's Office**, announcements on British Airways (16 October 2020, £20 million) and Marriott International (30 October 2020, £18.4 million): ico.org.uk. These were issued under the UK regime, which mirrors the GDPR.
- **No More Ransom**, free decryptors and advice: nomoreransom.org
- **ENISA and your national CSIRT or cyber agency**, for cyber incident guidance and reporting.

WATCH OUT **What this book could not verify for you**

The Digital Omnibus changes to breach notification (higher threshold, 96-hour deadline, single entry point) were proposals when this book was written, reported mainly by law-firm and vendor commentary, and should be checked against EUR-Lex and the European Parliament's procedure page. NIS2 scope and deadlines vary by national law. The scenarios in this book are fictional. Check each point against the primary source and take advice from a qualified professional before relying on it.

About the Author

Zirlandia Milkovic

Zirlandia Milkovic writes practical, plain-English guides on data protection, AI and building a business with confidence. She believes privacy is not a barrier to ambition but a foundation of trust, and that founders should not need a legal degree to understand the rules that apply to them.

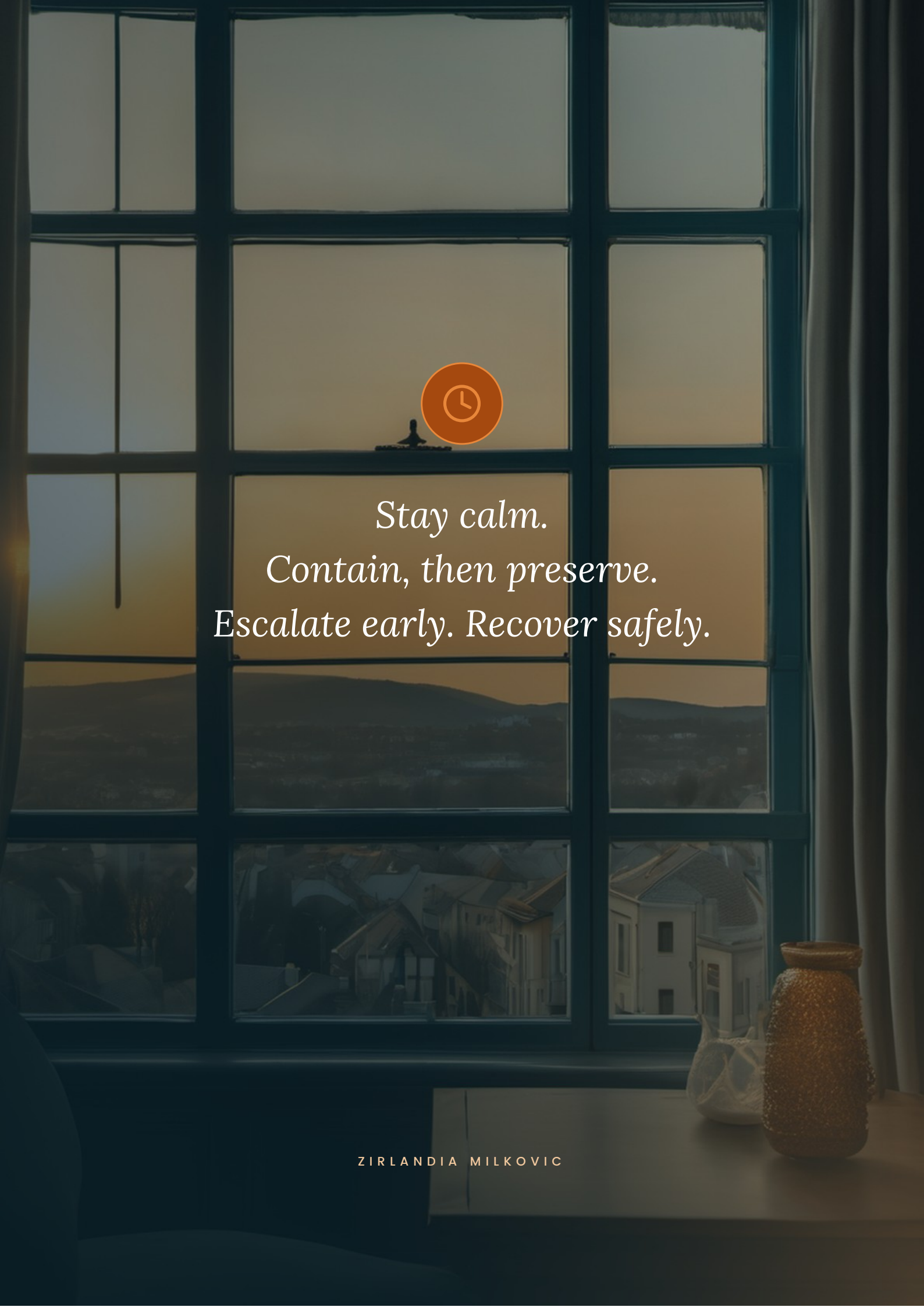
She is the author of a series of business guides, including *GDPR Made Simple for Women Founders*, and her work focuses on turning complex European rules into simple steps, checklists and templates that busy founders can actually use. She is also behind **GDPRGard**, a growing collection of free GDPR tools, guides and articles for small businesses, available at gdprgard.eu.

Stay in touch

Visit **gdprgard.eu** for free tools, articles and updates, including notes on changes to the rules covered in this book. If this guide helped you, an honest review where you bought it helps other businesses find it.

NOTE **Note to the reader**

This book is educational and not legal advice. Laws and guidance change, so check the sources in the previous section and consult a qualified professional about your own circumstances.


Stay calm.
Contain, then preserve.
Escalate early. Recover safely.
ZIRLANDIA MILKOVIC